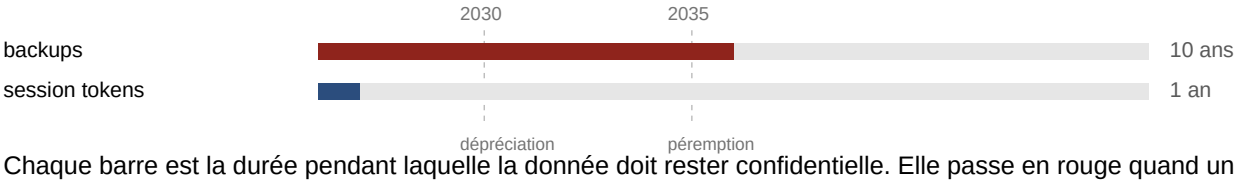
Sablier — Fixture

1 usage cryptographique protège des données dont la confidentialité doit durer au-delà de la péremption de l'algorithme qui les protège.

6 constats retenus sur l'ensemble analysé. Date de péremption retenue : 2035 — c'est l'échéance réglementaire, pas une prédiction de rupture cryptographique. Échéance vérifiée auprès de ses sources le 30/09/2026.

Durée de confidentialité des données, face à la péremption des algorithmes



Chaque barre est la durée pendant laquelle la donnée doit rester confidentielle. Elle passe en rouge quand un algorithme récoltable la protège au-delà du trait de péremption — dépasser le trait sans être rouge signifie que la donnée dure longtemps, mais qu'elle est protégée par de la cryptographie qui tiendra.

Dates de bascule

- backups — 10 ans — bascule franchie depuis 2026

Une donnée chiffrée l'année Y reste sensible jusqu'à Y + sa durée. L'année de bascule est donc celle à partir de laquelle tout ce qui est chiffré survit à la péremption de 2035 : avant, le domaine tient ; à partir d'elle, ce qui est émis est déjà perdu le jour où l'algorithme tombe.

COMPROMIS 1

RSA backups

Chiffré aujourd'hui, à garder confidentiel jusqu'en 2036 — soit 1 an après la péremption de RSA. Une capture faite maintenant sera lisible. Génération de clé RSA.

Accepter ce constat : sablier accept d45d9d61 --reason="…" --until=2027-05-02

L'outil a tort ? Ouvrir un signalement pré-rempli

CASSÉ AUJOURD'HUI 1

SHA-1 session tokens

Cassé classiquement, indépendamment du quantique. L'échéance était hier.

Accepter ce constat : sablier accept d87d2d2b --reason="…" --until=2027-05-02

L'outil a tort ? Ouvrir un signalement pré-rempli

SURVEILLER 2

RSA backups

Signature : pas de récolte possible. À migrer avant 2030 pour la conformité, sans urgence de confidentialité. Génération de clé SSH.

Accepter ce constat : sablier accept e51683bf --reason="…" --until=2027-05-02

L'outil a tort ? Ouvrir un signalement pré-rempli

RSA session tokens

Signature : pas de récolte possible. À migrer avant 2030 pour la conformité, sans urgence de confidentialité. Algorithme JWT.

Accepter ce constat : sablier accept a994f9c6 --reason="…" --until=2027-05-02

L'outil a tort ? Ouvrir un signalement pré-rempli

CONFORME 2

- deploy/backup.sh:4
- src/Tokens.php:22

PROBABLEMENT HORS SUJET 1

- src/Tokens.php:12

Ce que ce rapport n'a pas regardé

- la cryptographie de vos services gérés — base de données, stockage objet, terminaison TLS chez un intermédiaire — n'apparaît dans aucun fichier de ce dépôt
- ce qui est réellement négocié à l'exécution, pour tout hôte non déclaré dans la section « sonde »
- les clés détenues dans un HSM ou chez un fournisseur
- la durée de vie réelle des données : elle vient de votre déclaration, pas du code — un domaine non déclaré est calculé avec une durée par défaut de 3 ans
- L'horizon d'exploitation du système n'est pas déclaré : le calcul suppose qu'il cesse d'écrire des données aujourd'hui. C'est l'hypothèse optimiste — un service encore en production dans dix ans produira dix ans de données de plus à protéger. Ajoutez `service_until` à la déclaration.
- Échéance retenue : 2035, d'après NIST IR 8547. Un autre cadre — institutionnel, défense — donne une autre date : voir `regime` dans la déclaration.
- Les sommes de contrôle (CRC32, Adler-32) ne sont signalées qu'à côté d'un jeton, d'un lien ou d'un secret. Une clé de Luhn ou un modulo écrits à la main ne le sont jamais : rien ne les distingue d'un calcul ordinaire, et un code qui accepte un numéro sur la foi de son chiffre de contrôle n'apparaît pas ici.
- Les fichiers binaires (images, polices, archives) ne sont lus que sur leurs premiers méga-octets, et seulement pour trois signes vérifiables : un bloc de clé, des octets après la fin de l'image, une extension qui ment sur le contenu. Un message dissimulé dans les bits d'une image n'est pas détecté ici, et ne prétend pas l'être.
- Les fichiers YAML de configuration sont lus comme du texte, pas interprétés : un algorithme défini par un paramètre, par un fichier importé ou par une variable d'environnement n'est pas vu ici.

Un inventaire qui ne dit pas ce qu'il n'a pas vu n'est pas un inventaire.

Ce qu'il a cherché et n'a pas trouvé

Chaque ligne est un résultat, pas un silence : un détecteur a ouvert ces fichiers et n'en a rien tiré. Le nombre est là pour que vous puissiez juger la portée de la phrase plutôt que la croire.

- 3 fichier(s) lu(s) : aucune clé privée, aucun certificat, aucun magasin de clés dans l'arborescence versionnée.

Ce qu'il y a à changer

4 emplacement(s) à reprendre, dans 2 fichier(s). Les lignes ci-dessous comptent des endroits, pas des semaines.

Algorithme	Appels	Fichiers	Domaines	Ce que cela change
RSA · signature	2	2	2	
RSA · chiffrement	1	1	1	

SHA-1	1	1	1

La feuille de route européenne compte l'effort de migration parmi les trois facteurs du risque quantique. Cet outil le compte en emplacements parce que c'est ce qu'un dépôt sait dire ; il n'en fait pas une durée. Huit appels dans un fichier derrière une même fonction sont une après-midi ; huit répartis sur six services avec un protocole entre eux sont un trimestre, et rien dans les fichiers ne distingue les deux. Cette estimation vous appartient.

Ce qu'il faut faire, dans l'ordre

Un inventaire qui ne conclut rien se range dans un dossier. Voici l'arbitrage — et l'ordre compte autant que la liste.

- Décider du sort des données déjà émisesC'est la décision que personne ne prend, et elle vient avant la migration. Les domaines concernés (backups) sont protégés par un algorithme qui ne tiendra pas jusqu'au bout de leur durée de confidentialité : ce qui a déjà été chiffré et transmis est hors de portée d'un correctif. Trois issues, et il faut en choisir une explicitement — re-chiffrer le stock existant avec un algorithme qui tient, faire tourner les clés et réémettre ce qui peut l'être, ou acter par écrit qu'on accepte le risque sur les données antérieures à 2035. Migrer sans trancher cette question protège les données futures et laisse les anciennes exposées sans que personne ne l'ait décidé.
- Remplacer ce qui est déjà cassé Un usage repose sur un algorithme cassé classiquement. Aucun raisonnement quantique n'est nécessaire : l'échéance était il y a dix ans, le remplacement est connu et ne demande pas un projet. À traiter avant tout ce qui concerne la transition post-quantique, parce que c'est moins cher et déjà exploitable.
- Remettre ce rapport au calendrierLa fenêtre se referme d'elle-même : la date de péremption ne bouge pas (2035), mais chaque année qui passe rapproche vos données de cette ligne. Un domaine conforme aujourd'hui avec une durée de neuf ans ne le sera plus l'an prochain. Rejouer l'analyse une fois par an suffit — et vérifier à cette occasion que l'échéance réglementaire n'a pas bougé.

Envoyer le résumé sur Threema

Ouvre Threema sur un téléphone où l'application est installée. Sur un ordinateur, le schéma n'est en général pas enregistré et le navigateur refuse le lien : copiez le texte ci-dessous. Rien n'est transmis à un serveur tiers.

Faux positif ?

Deux choses s'appellent « faux positif », et elles ne vont pas au même endroit.

1. L'outil a raison, mais ce constat est accepté ici. C'est une décision de projet : ajoutez ce bloc à votre déclaration, elle est versionnée, donc la relecture se fait en revue de code. La raison et la date d'expiration sont obligatoires.

En ligne de commande : sablier accept <empreinte> --reason="…" --until=2027-05-02

2. L'outil a tort. C'est une règle à corriger, et sa place est dans le dépôt de Sablier : github.com/mesa-black/sablier

L'empreinte imprimée à côté de chaque constat le désigne, et c'est elle qu'on cite dans les deux cas. Elle est calculée sur la preuve, pas sur le numéro de ligne : elle survit à un déplacement du code, et change le jour où la ligne change vraiment.

Empreinte et signature

empreinte des constats 92cd7996cbe685ae50aae64e425865da36bd3c25b0ac6341ca1668dfd1e5431d

L'empreinte porte sur les constats, pas sur ce fichier : deux rendus du même inventaire, dans deux langues, donnent la même valeur.